



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Secure System Design and Principles

Understanding Threats

- Defacement
- Infiltration
- Phishing
- Pharming
- Insider threats
- Click fraud
- Denial-of-service
- Data theft/Loss



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Defacement

- Attackers replace legitimate pages with illegitimate ones
- Targeted towards political websites



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Understanding Threats

- Defacement
- Infiltration
- Phishing
- Pharming
- Insider threats
- Click fraud
- Denial-of-service
- Data theft/Loss



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Infiltration



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Infiltration allows an attacker to gain access to the resources of the computer system
- Could gain read/write access to the back-end DB
 - SQL injection
 - Email font injection (website font)

Understanding Threats

- Defacement
- Infiltration
- Phishing
- Pharming
- Insider threats
- Click fraud
- Denial-of-service
- Data theft/Loss



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

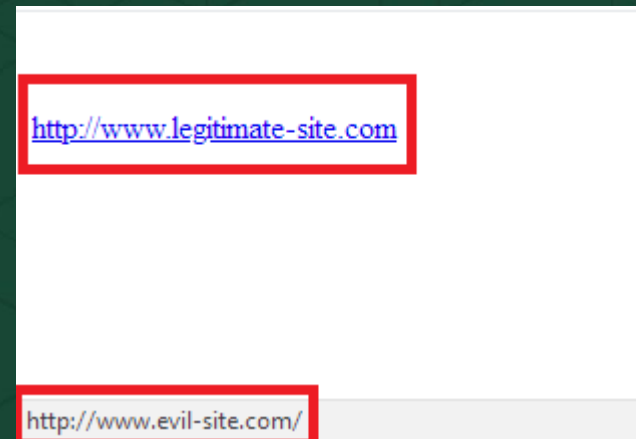
Phishing



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Attacker sets up spoofed site that looks real
 - Email spam filter phishing

```
<a href="http://www.evill-site.com/">  
http://www.legitimate-site.com/  
</a>
```



Understanding Threats

- Defacement
- Infiltration
- Phishing
- Pharming
- Insider threats
- Click fraud
- Denial-of-service
- Data theft/Loss



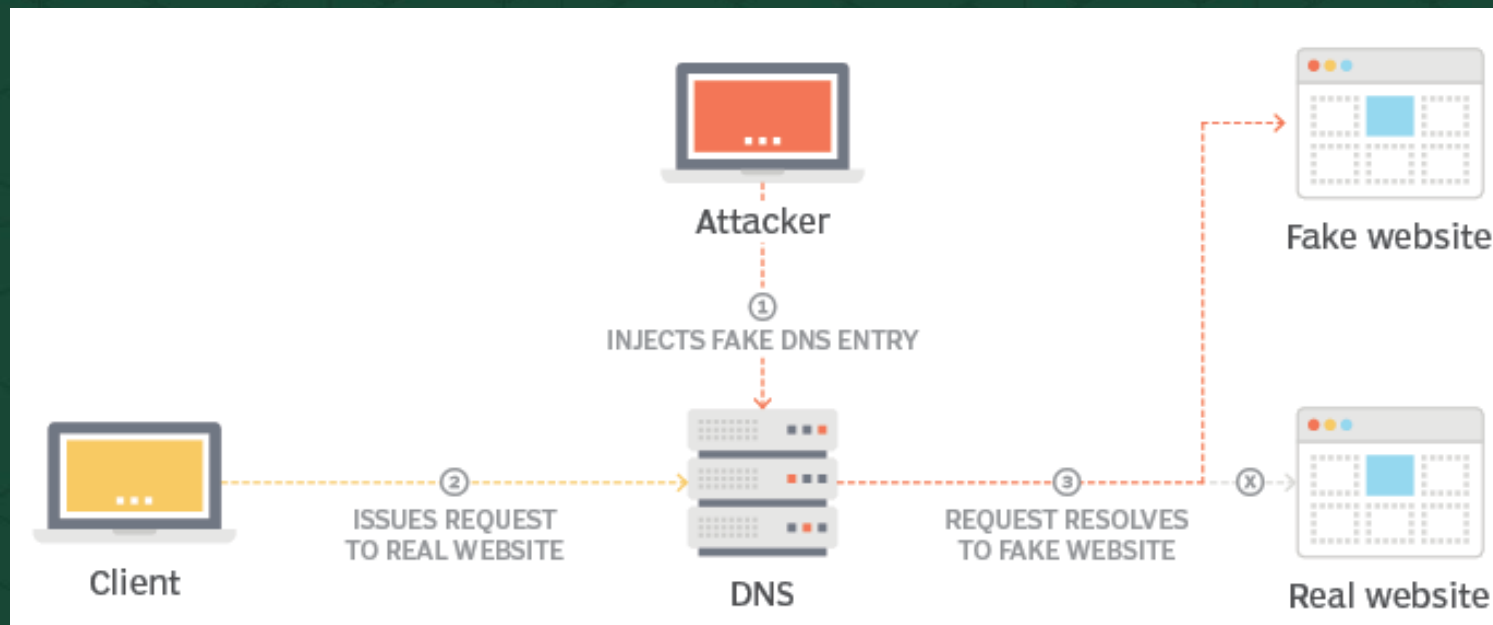
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Pharming



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- DNS Cache Poisoning – attacker is able to redirect legitimate URLs to their spoofed site
- DNS translates an URL to appropriate an IP address



Understanding Threats

- Defacement
- Infiltration
- Phishing
- Pharming
- Insider threats
- Click fraud
- Denial-of-service
- Data theft/Loss



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Insider Threats

- Attacks are carried out with the cooperation of insiders
 - Insiders can have the access to the data and leak the data
 - Ex: Database administrators usually have complete access to all data



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Understanding Threats

- Defacement
- Infiltration
- Phishing
- Pharming
- Insider threats
- Click fraud
- Denial-of-service
- Data theft/Loss



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Click Fraud



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Attacker could click on its competitor's ads
 - Depletes other's ad budgets, gains exclusive attention of legitimate users
- Serverless Denial of Wallet attack

Understanding Threats

- Defacement
- Infiltration
- Phishing
- Pharming
- Insider threats
- Click fraud
- Denial-of-service
- Data theft/Loss



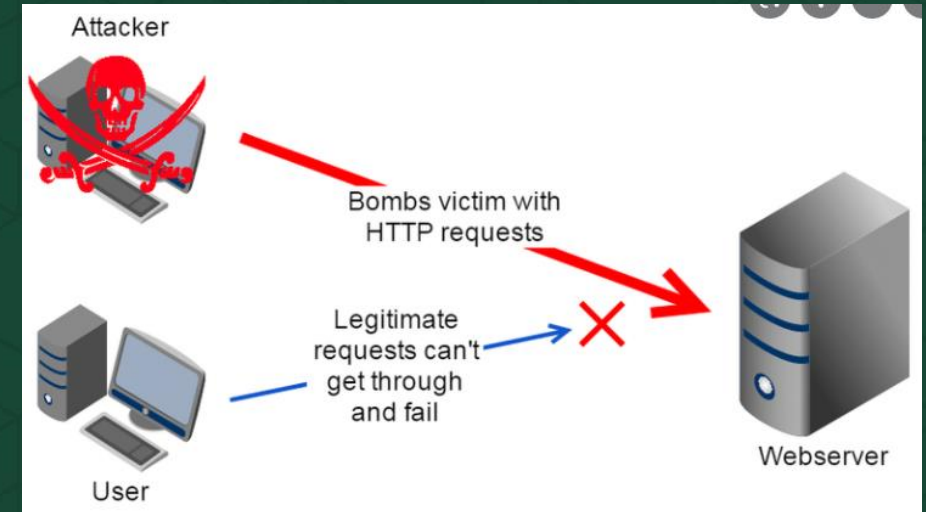
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Denial of Service (DoS)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- DoS V.S. DDoS
 - Usually launched in the form of distributed Denial-of-service attack (DDoS)
- Regular expression Denial-of-service (REDOS) attack is a new variant.
 - $^+(a+)+\$$
 - $^+a+ \$$



Understanding Threats

- Defacement
- Infiltration
- Phishing
- Pharming
- Insider threats
- Click fraud
- Denial-of-service
- Data theft/Loss



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Data Theft and Data Loss

- Example BofA: backup data tapes lost in transit
- Even for encrypted data, should store keys in separate media
 - Banking data (public key & private key)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Designing-In Security



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Design features with security in mind
 - Not as an afterthought
- Hard to “add-on” security later

Windows 98

- Diagnostic Mode:
 - Accessed through 'F8' key when booting
 - Can bypass password protections
 - Giving attacker complete access to hard disks & data
- Username/Password Security was added as an afterthought



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

The Internet



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

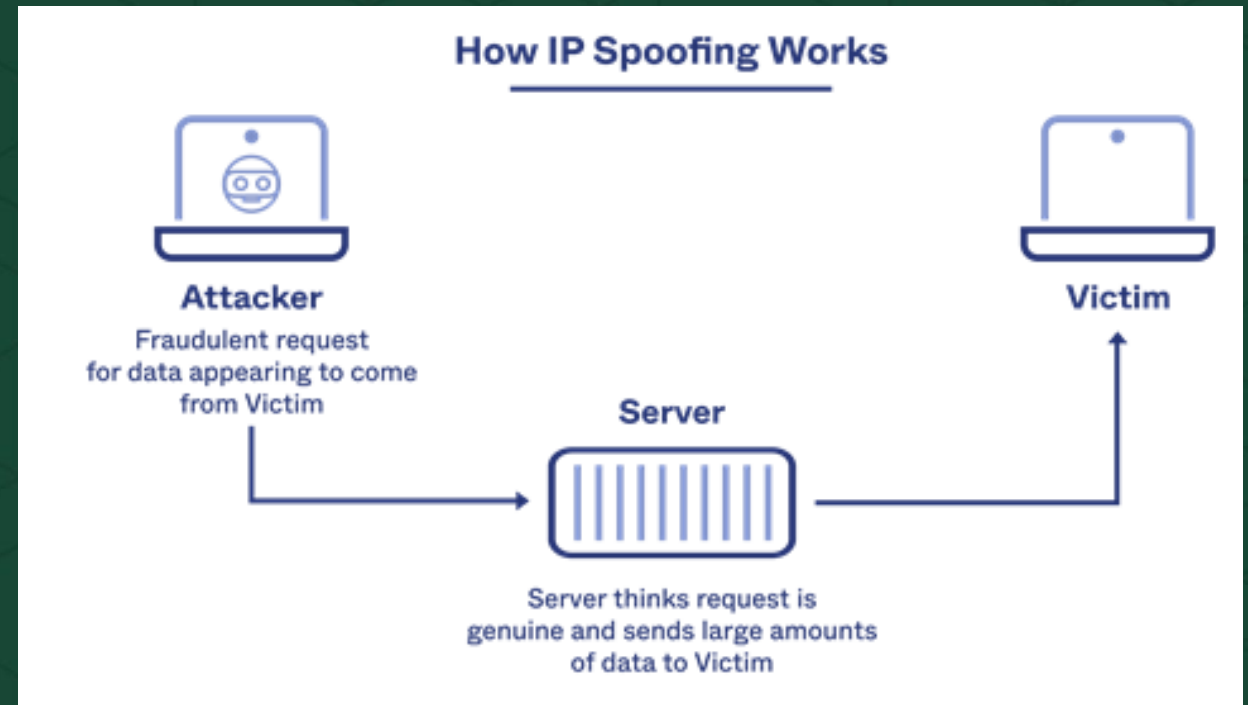
- All nodes originally university or military (i.e. trusted) since it grew out of DARPA
- With commercialization, lots of new hosts, all allowed to connect to existing hosts regardless of whether they were trusted
- Deployed Firewalls: allows host to only let in trusted traffic
- Loopholes: lying about IP addresses, using cleared ports

IP Whitelisting & Spoofing

- IP Whitelisting: accepting communications only from hosts with certain IP addresses
- IP Spoofing attack: attacker mislabels (i.e. lies) source IP address on packets, slips past firewall



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



IP Spoofing & Nonces



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

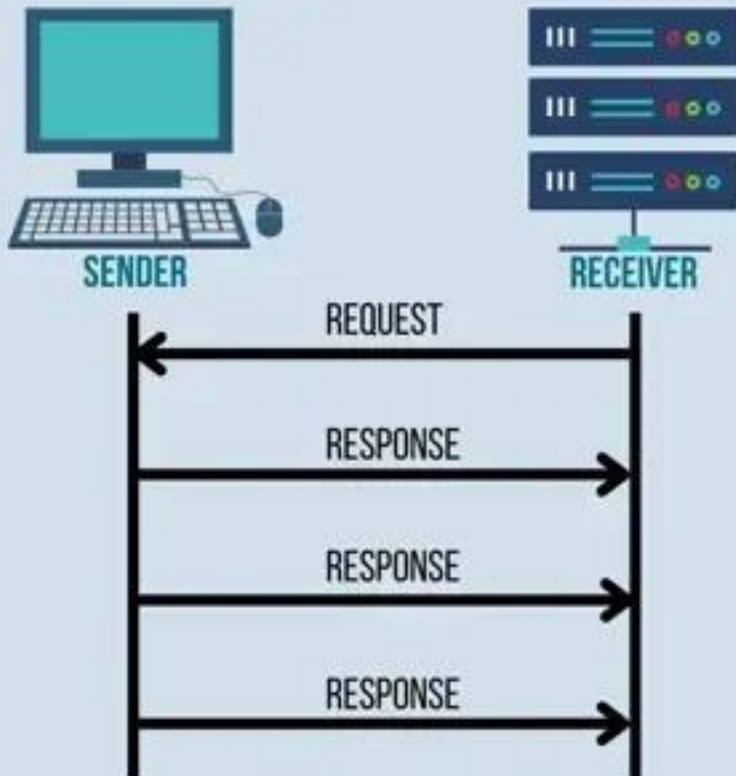
- *Nonce*: one-time pseudorandom number
- Defense: Attaching a nonce to a reply and requesting it to be echoed back can guard against IP spoofing
- Attacker won't know what reply to fake
- Spoofing easier for non-connection-oriented protocols (e.g. UDP) than connection-oriented (e.g. TCP)
- TCP sequences (i.e., nonces) should be random, otherwise, an attacker can predict and inject packets into conversation

TCP & UDP

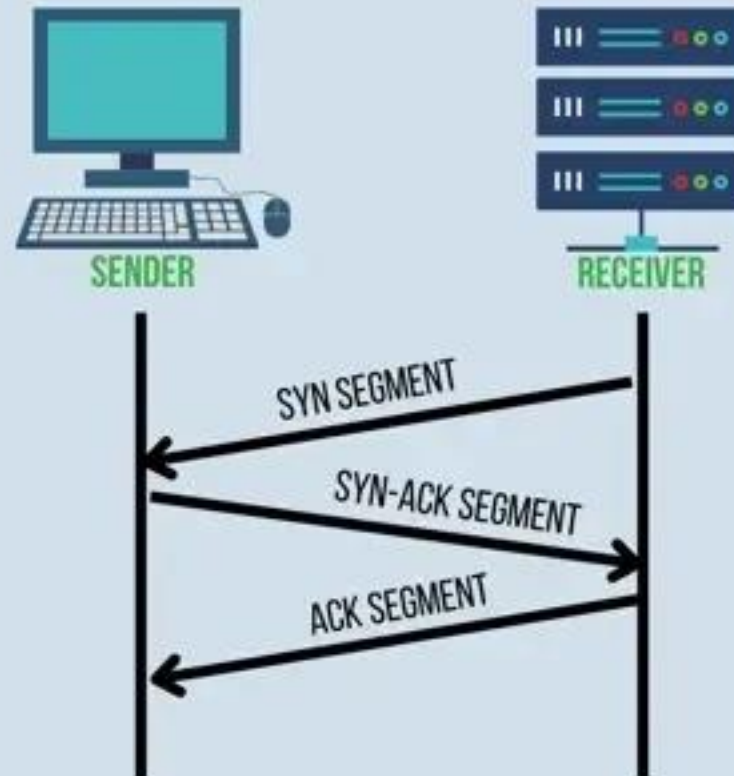


MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

UDP



TCP



Turtle Shell Architectures



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Inherently insecure system protected by another system mediating access to it
 - Ex: Firewalls guard vulnerable systems within
- Turtle Shell (i.e. A hard outer shell) should not be sole defense
 - Zero-day attacks

Convenience and Security



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Sometimes inversely proportional
 - More secure -> Less convenient
 - Too Convenient -> Less secure
- If too inconvenient -> unusable -> users will workaround -> insecure
 - Ex: users may write down password in plaintext
- Good technologies increase relative security benefit at only slight inconvenience

Simple Web Server (SWS)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- To illustrate what can go wrong if we do not design for security in our web applications from the start, consider a simple web server implemented in Java.
- Only serves documents using HTTP
- Walk through the code in the following slides

Hypertext Transfer Protocol



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- HTTP is the communications protocol used to connect to servers on the Web
- Primary function is to establish a connection with a server and transmit HTML pages to client browsers or any other files required by an HTTP application.
- Website addresses begin with an **http://** prefix.

HTTP



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- A typical HTTP request that a browser makes to a web server for the server's homepage is: *Get / HTTP/1.0*
- When the server receives this request, it attempts to load the file *index.html*. Return *HTTP /1.0 200 OK* followed by the document content of *index.html*
- A browser can also specify a filename and request this file from a web server by using *Get / HTTP/1.0*. In this case, the server returns the document content of the filename specified by the browser.

SimpleWebServer: main



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

```
/* This method is called when the program is run from the command  
line. */
```

```
public static void main (String argv[]) throws Exception {  
    /* Create a SimpleWebServer object, and run it */  
    SimpleWebServer sws = new SimpleWebServer();  
    sws.run();  
}
```

SimpleWebServer: Object

```
Public class SimpleWebServer {
```

```
    /* Run the HTTP server on this TCP port. */
```

```
    private static final int PORT = 8080;
```

```
    /* The socket used to process incoming connections from web clients */
```

```
    private static ServerSocket dServerSocket;
```

```
    public SimpleWebServer () throws Exception {
```

```
        dServerSocket = new ServerSocket (PORT);
```

```
    }
```

```
    public void run () throws Exception {
```

```
        while (true) {
```

```
            /* wait for a connection from a client */
```

```
            Socket s = dServerSocket.accept();
```

```
            /* then process the client's request */
```

```
            processRequest(s);
```

```
        }
```

```
    }
```



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

SimpleWebServer: processRequest

```
public void processRequest(Socket s) throws Exception {  
    /* Used to read data from the client. */  
    BufferedReader br = new BufferedReader (new InputStreamReader(s.getInputStream()));  
    /* Used to write data to the client. */  
    OutputStreamWriter osw = new OutputStreamWriter (s.getOutputStream());  
    /* read the HTTP request from the client */  
    String request = br.readLine();  
    String command = null;  
    String pathname = null;
```



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

SimpleWebServer: processRequest

```
/* parse the HTTP request */
StringTokenizer st = new StringTokenizer (request, " ");
command = st.nextToken();
Pathname = st.nextToken();
if (command.equals("GET")) {
    /* if the request is a GET try to respond with the file the user is requesting */
    serveFile (osw, pathname);
} else {
    /* if the request is a NOT a GET, return an error saying this server does not
    implement the requested command */
    osw.write("HTTP /1.0 501 Not Implemented \n\n");
}
/* close the connection to the client */
Osw.close();
```



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

SimpleWebServer: serveFile

```
public void serveFile (OutputStreamWriter osw, String pathname) throws Exception {  
    FileReader fr = null;  
    int c = -1;  
    StringBuffer sb = new StringBuffer();  
    /* remove the initial slash at the beginning of the pathname in the request */  
    if (pathname.charAt(0) == '/')  
        pathname = pathname.substring(1);  
    /* if there was no filename specified by the client, serve the "index.html" file */  
    if (pathname.equals(""))  
        pathname = "index.html";  
}
```



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

SimpleWebServer: serveFile

```
/* try to open file specified by pathname */  
try {  
    fr = new FileReader (pathname);  
    c = fr.read();  
} catch (Exception e) {  
    /* if the file is not found, return the appropriate HTTP response code */  
    osw.write("HTTP /1.0 404 Not Found\n\n");  
    return;  
}
```



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

SimpleWebServer: serveFile



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

```
/* if the requested file can be successfully opened and read, then return an OK  
response code and send the contents of the file */
```

```
osw.write("HTTP /1.0 200 OK \n\n");  
while (c != -1) {  
    sb.append((char)c);  
    c = fr.read();  
}  
osw.write(sb.toString());
```

DoS on SWS Example

```
processRequest():
```

```
/* read the HTTP request from the client */
```

```
String request = br.readLine(); -> empty string !
```

```
String command = null;
```

```
String pathname = null;
```

```
/* parse the HTTP request */
```

```
StringTokenizer st = new StringTokenizer (request, " ");
```

```
Command = st.nextToken(); // EXCEPTION: no tokens!
```

```
/* SERVER CRASHES HERE – DENIAL OF SERVICE! */
```



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

How Do We Fix This?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- The web server should immediately disconnect from any web client that sends a malformed HTTP request to the server.
- The programmer needs to carefully handle exceptions to deal with malformed requests.
- Solution: Surround susceptible String Tokenizing code with try/catch block.

Try/Catch Solution

```
/* read the HTTP request from the client */
String request = br.readLine();
String command = null;
String pathname = null;
try {
    /* parse the HTTP request */
    StringTokenizer st = new StringTokenizer(request, " ");
    command = st.nextToken();
    pathname = st.nextToken();
} catch (Exception e) {
    osw.write("HTTP /1.0 400 Bad Request \n\n");
    osw.close();
    return;
}
```



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Specifying Error Handling Requirements



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Vulnerabilities often due to bad error handling
- Example: DoS on SWS – makes it unavailable
- Just send a carriage return as the first message instead of a properly formatted GET message... GET / HTTP/1.0 (\r\n)
- Causes exception when breaking into tokens

Test Cases are useful to identify problems



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Should have test cases for security: Does it malfunction when provided bad input?
- Ping-of-Death: sending a packet of data can cause server to crash
 - Ex: DoS attack on SimpleWebServer
 - Ex: Nokia GGSN crashes on packet with TCP option field set to 0xFF

Handling Internal Errors Securely



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Error messages and observable behavior can tip off an attacker to vulnerabilities.
- Fuzz testing: Providing a program with input that it does not expect (as in the DoS attack against SimpleWebServer) and observing its behavior.
- “Ethical” hackers often hired to find such bugs

Including validation and fraud checks



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Credit Card Example:

- Mod 10 Checksum: ensures validity of number, to catch user typos
- CVC: guards against fraudsters who have stolen credit card number but don't know the CVC
- Full Credit Card Check might be too costly
- VISA/ Master Card Mod 10 Checksum:
 - For each digit (counting positions from the **left**, starting at 1):
 - If position is **odd** (1,3,5,...,15): **double** the digit.
 - If the result is **10–18**, replace it with **result – 9** (same as adding the two digits).
 - If position is **even**: keep it as is.
 - Sum all resulting values.
 - Valid iff **sum is a multiple of 10**.
 - 4 2 4 2 4 2 4 2 4 2 4 2 4 2 4 2
 - 7 9 9 9 2 7 3 9 8 7 1 3 0 0 0 3

Writing Measurable Security Requirements



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Access Control Security: Only certain users can do certain functions
- Auditing: Maintain log of users' sensitive actions
- Confidentiality: encrypt certain functions' output
- Availability: Certain features should be available almost always
- Include these requirements in design docs!
- Requirements should specify which error cases & threats to handle

Security or Bust

- Should not ship code unless its secure
- Advantage gained by launching earlier could be lost due to vulnerabilities that tarnish brand and lead to lost revenue
- Ex: Microsoft delayed ship of .NET server in '02 because security requirements not met by “code freeze” deadline



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

External Materials



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- What is access token
 - https://en.wikipedia.org/wiki/Access_token
- Serverless functions & DoS attack:
 - <https://www.contentful.com/blog/serverless-functions/>
 - <https://ieeexplore.ieee.org/document/10630835>
 - <https://dl.acm.org/doi/10.1145/3548606.3560629>
- How font works?
 - https://adobe-type-tools.github.io/font-tech-notes/pdfs/5012.Type42_Spec.pdf
- Digital Signatures in a PDF & attack paper
 - <https://www.vandanaintl.com/downloads/USE%20DSC%20IN%20PDF.pdf>
 - https://www.ndss-symposium.org/wp-content/uploads/ndss2021_1B-4_24117_paper.pdf

External Materials



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Https, Certificate:
 - <https://www.cloudflare.com/learning/ssl/what-is-https/>
- Famous DDoS attacks
 - <https://www.cloudflare.com/learning/ddos/famous-ddos-attacks/>
- Regular Expressions (regexp)
 - <https://www.ibm.com/docs/en/zvm/7.3.0?topic=reference-regular-expressions-regexp>
- LLM guardrails
 - <https://www.datadoghq.com/blog/llm-guardrails-best-practices/>
 - <https://www.ibm.com/think/tutorials/llm-guardrails>